

O-NYX — Full Security Pipeline Timeline

Gateway Interception to Post-Exploitation (TRACE)

This document traces one file, end to end, through every stage of the pipeline: interception at the network edge, every automated security check and the exact parameters each one inspects, the trust-score decision, the digital-twin detonation stage, and the full post-exploitation (TRACE) forensic-and-disposal chain. It is written as the master technical reference for the UROP research paper — every layer, every check, and every parameter the system evaluates is listed here so nothing has to be reconstructed from memory when writing the paper's architecture or methodology sections.

Three working names appear across the project's existing files for what is really one system: **O-NYX** (pre- and mid-exploitation: interception, scoring, digital twin, covert agent), **SentinelVault** (an earlier name for the same full lifecycle), and **TRACE** (the post-exploitation forensics-and-disposal module). This document treats them as one continuous pipeline, in the order the file actually moves through it.

Stage 0 — Entry: Network Gateways (Interception Chokepoints)

No file is ever intercepted on an employee's own device. All interception happens at network-level chokepoints, chosen because they scale independent of employee headcount — one gateway covers every employee, not one agent per machine.

Gateway	What passes through it	Why it's a chokepoint
Email Gateway / MTA	Attachments, embedded links, sender identity	Every inbound/outbound email must pass through the mail transfer agent before reaching an inbox
Web / Forward Proxy	Downloads, uploaded files, browsing traffic	All outbound HTTP/HTTPS from employee devices is forced through the proxy
DNS Resolver	Domain lookups before any connection is made	Malware and phishing sites must resolve a domain first; this is interceptable before a single packet reaches the destination

Gateway	What passes through it	Why it's a chokepoint
CASB (Cloud Access Security Broker)	Files moving to/from SaaS storage (Google Drive, OneDrive, Dropbox, Slack uploads)	Cloud traffic bypasses the on-prem proxy unless a CASB sits in that path
Internal File-Share Filter	Files moved between internal servers/shares (SMB, NFS)	Catches lateral movement of a file that already got past the perimeter
USB / Removable-Media Control (exception)	Files introduced via USB, external drives	The only vector that bypasses every network chokepoint — this is the one case needing a lightweight per-endpoint agent (device-control policy), not a full inspection pipeline

Every gateway above calls the **same centralized AI Pre-Screening Engine** as a backend service — the scoring logic is not duplicated per gateway. A gateway's only job is capture and forwarding; all analysis happens in the layers below.

Pre-Exploitation — Layer 1: Fast Pre-Screening Checks

These run first because they're cheap and fast — most benign files are cleared here in milliseconds without ever touching the deeper, slower Layer 2 checks.

Check	What it inspects	Parameters evaluated	Output
Hash Reputation Lookup	File identity	MD5 / SHA-1 / SHA-256 hash, matched against known-malware hash databases (local blocklist + threat-intel feeds)	Hit / miss + confidence score
YARA Rule Matching	File content patterns	Packer signatures, known malware-family byte patterns, suspicious string patterns, obfuscation markers	Number of rules matched + severity weight per rule

Check	What it inspects	Parameters evaluated	Output
ML Classifier (static-feature model)	File structure, without execution	File entropy, PE header anomalies, import-table API calls (e.g. VirtualAlloc, WriteProcessMemory, CreateRemoteThread), section characteristics, packer detection, embedded strings (URLs/IPs/keywords)	Malicious-probability score (0-1)
Phishing-URL Check (for links/attachments linking out)	Any embedded or sender URL	Domain age, SSL certificate validity, homoglyph/typosquat detection against known brand names, URL reputation feeds, redirect-chain analysis	Phishing-likelihood score

All four checks run in parallel wherever possible. Their raw outputs are passed forward — unscored individually — to Layer 3 for fusion. Layer 1 does **not** make a block/pass decision on its own.

Pre-Exploitation — Layer 2: Parallel Deep-Inspection Systems

Slower, heavier checks, run in parallel with each other (not sequentially) on anything Layer 1 didn't already clear with high confidence.

System	What it inspects	Parameters evaluated	Output
Static Analysis (deep)	File internals without execution	Disassembly-level control-flow anomalies, embedded PE/script objects inside documents, macro (VBA) analysis, obfuscation/packing ratio, per-section entropy, digital-signature validity, compiler/linker timestamp anomalies	Structured anomaly report
CDR (Content Disarm & Reconstruction)	Active content inside documents/attachments	Macros, embedded OLE objects, embedded JavaScript (e.g. in PDFs), executable objects	Rebuilds the file into a flattened, safe version — runs regardless of verdict
Honeypot Network Observer	Decoy assets elsewhere on the network	Decoy credential usage, decoy file-access attempts, canary-token triggers, lateral-movement probes against decoy assets, DNS requests to honeypot domains	Early warning signal if something is already probing
Ransomware "Time Machine"	Live filesystem I/O patterns	Continuous lightweight snapshots, baseline vs. abnormal I/O pattern comparison, entropy-change detection on file writes (a hallmark of encryption)	Rollback point created continuously, independent of this file's verdict

These four run alongside each other. Their combined output, together with Layer 1's results, feeds into Layer 3.

Pre-Exploitation — Layer 3: Attacker-Intent Engine (Trust/Risk Score Fusion)

This is the single centralized AI scoring service every gateway calls. It does not inspect the file itself — it fuses the signals Layers 1 and 2 already produced into one number.

Inputs fused: hash-lookup result, YARA match count/severity, ML static-classifier probability, phishing-URL score, static-analysis anomaly report, CDR findings, honeypot signal, time-machine I/O anomaly flag.

Fusion method: weighted signal aggregation (each signal source assigned a weight reflecting its reliability — e.g. a hash match is weighted higher/more decisive than a single YARA hit) combined into one ensemble score.

Output: one unified **0-100 trust/risk score** per file.

Score band	Meaning
0-30	Low risk — behaves like a benign file
31-70	Medium risk — ambiguous signals, needs behavioral confirmation
71-100	High risk — strong indicators of malicious intent

Important clarification: this score is a risk/trust rating only. It is *not* a malware-type classification — the engine never says "this is ransomware" at this stage. That classification can only happen after the file is actually observed behaving, which is why it belongs to mid-exploitation, not here. The framing to use in the paper: **pre-exploitation triages risk; mid-exploitation classifies the threat.**

Pre-Exploitation — Layer 4: Policy / Decision Engine

Takes the Layer 3 trust score and converts it into an action. This is the last pre-exploitation step — nothing past this point is "pre-exploitation" anymore.

Score band	Action taken	What the employee experiences
Low (0-30)	Pass — file delivered normally	No visible delay or interruption
Medium (31-70)	Sandbox — routed into an ephemeral digital-twin instance for behavioral confirmation	File appears "pending" for the duration of the mid-exploitation run

Score band	Action taken	What the employee experiences
High (71–100)	Block — file is quarantined immediately, no twin is ever created	Employee cannot download/open the file; SOC is alerted

Two policy layers can sit on top of these base thresholds: organization-wide policy (e.g. stricter thresholds for finance or HR than general staff) and a human-override/approval hook for edge cases. No containment or blocking action beyond this automatic triage ever executes without a human approval gate — this human-in-the-loop principle holds across every phase of the pipeline, not just here.

Only a **medium** score causes anything to move into mid-exploitation. A low score never creates a twin at all; a high score blocks before a twin is ever considered.

Mid-Exploitation — Step 1: Digital-Twin Instantiation

Triggered only by a medium trust score. The system builds one disposable instance of the organization's digital twin — not a single VM, but a whole miniature multi-node network.

Twin component	Purpose
Fake Domain Controller	Mimics real authentication/domain structure
Fake File Server	Holds decoy files matching real folder conventions
Fake Email Server	Lets the sample interact with "internal" email if it tries to spread
Fake Database	Decoy records for the sample to probe or exfiltrate
Fake Backup Server	Needed to observe ransomware behavior realistically (does it target backups?)
Fake Employee Endpoints	One or more machines resembling real employee laptops
Detonation-Point VM	The one specific machine where the suspicious file is actually placed and run

The twin's realism (hostnames, domain structure, folder conventions) is built from a one-time plus continuously-updated network-discovery process against the real organization, so the fake network is indistinguishable from the real one from the sample's point of view — this is precisely what defeats sandbox-evasion techniques that check for "am I in a fake environment?" before activating.

One twin blueprint exists per organization (not one per employee). Ephemeral *instances* of that one blueprint are spun up on demand, one per detonation, and destroyed after — so many files can each get their own disposable instance without needing a separate permanent twin per employee.

Mid-Exploitation — Step 2: Covert Hypervisor-Level AI Agent

The observer does not run inside any of the twin's fake machines — it watches from the hypervisor layer, one level below every VM in the twin, using Virtual Machine Introspection (VMI). This is the core anti-evasion mechanism: nothing running inside the twin can detect, disable, or see the observer, because it isn't a process the guest OS can enumerate.

Monitoring channel	What it captures
Memory introspection	Process memory contents, injected code, in-memory-only payloads
Syscall monitoring	Every system call the sample or any spawned process makes
Process-creation monitoring	New processes spawned, parent/child relationships, process-hollowing attempts
Network-traffic capture (inside the twin)	Every connection attempt the sample makes to any twin node or simulated external address
Filesystem/registry change monitoring	File writes/deletes/renames, registry key changes

The agent runs four continuous functions while the file executes:

1. **Behaviour watcher** — logs every event above as it happens
2. **Intent classifier** — groups observed behaviour into recognizable patterns (e.g. "mass file renaming + extension change" = encryption-like pattern)
3. **ATT&CK mapper** — maps each observed pattern to a MITRE ATT&CK technique ID (e.g. T1003 Credential Dumping, T1486 Data Encrypted for Impact, T1071 Application Layer Protocol for C2)
4. **Risk scorer** — maintains a running behavioural risk score as the run progresses

By design, the agent does **not** stream a live verdict. It stays silent until the file's entire run is finished (or a timeout is hit), then produces one complete forensic report. This is deliberate: a batch report after full execution is more reliable than trying to interrupt and judge a sample mid-behaviour.

Mid-Exploitation — Step 3: Detonation Through Disposal

Step	What happens
Detonation	The file is placed on the Detonation-Point VM and allowed to execute exactly as it would on a real employee machine
Full-run observation	The covert agent (Step 2) watches until the sample finishes its activity or a timeout is reached
Classification	Only now — after real behaviour has been observed — does the system decide what <i>type</i> of threat this is: ransomware, trojan, worm, RAT, botnet client, or benign. This could not happen any earlier because nothing had actually run yet
Blast-radius analysis	Using the twin's topology (which mirrors the real org), the system works out what the sample would have reached next on the real network — which real asset is at risk first, second, third
Containment recommendation	A recommended response is prepared (isolate X, block Y, restore Z from backup) — but it is never auto-executed; a human must approve it first
Disposal	The entire twin instance is torn down: VM termination, memory zeroing, disk cryptoshredding, VPC teardown

Important clarification on disposal: disposal is **unconditional** — it happens after every single run, regardless of whether the file turned out malicious or harmless. It is not triggered by "the score being too high." What *is* verdict-dependent is the containment action recommended in the step above, not the disposal of the twin itself. A twin instance never persists after its one detonation run, by design.

Post-Exploitation — TRACE Step 1: Evidence Harvest and Sealing

Before anything is torn down, every piece of evidence from the run is collected and sealed.

Evidence item	What it contains
Memory dump	Full memory image of the Detonation-Point VM at end of run
Network capture (PCAP)	Every packet sent/received inside the twin during the run
Filesystem diff	Every file created, modified, or deleted during the run
Covert agent's full report	The complete behaviour log, intent classification, and ATT&CK mapping from Step 2 of mid-exploitation

Sealing process: the full evidence bundle is hash-chained (each piece cryptographically linked to the next, so tampering with any one piece breaks the chain) and cryptographically signed. This sealed bundle is committed to an **immutable audit store** before disposal is allowed to proceed — evidence integrity is guaranteed to survive even though the environment it came from will not.

Post-Exploitation — TRACE Step 2: Verified Disposal

Only once evidence is safely sealed in the immutable audit store does disposal actually proceed.

Disposal action	What it guarantees
VM termination	Every VM in the twin instance is shut down
Memory zeroing	RAM contents overwritten so nothing can be recovered from memory
Disk cryptoshredding	Disk encryption keys destroyed, making all disk data permanently unrecoverable
VPC teardown	The entire virtual network the twin ran in is deleted

Disposal certificate: a signed record is generated proving the teardown actually happened and was complete — this is the "verifiable/attestable disposal" piece, and it's one of the more novel parts of the whole pipeline, since most existing sandbox systems don't produce cryptographic proof that nothing persisted after analysis.

Post-Exploitation — TRACE Step 3: Intelligence Extraction and Distribution

Output	Contents	Distribution rule
IOC package	Hashes, IPs, domains, file paths observed during the run	Converted to STIX/TAXII format, pushed to MISP — instant for regular IOCs
ATT&CK technique map	Every MITRE technique ID observed (from Step 2 of mid-exploitation)	Distributed with the IOC package
TTP-similarity report	How this sample's behaviour compares to known campaigns/families	Distributed with the IOC package; deliberately avoids attribution claims, focuses on behaviour/TTP similarity only
Zero-day candidate flag	Raised only if behaviour doesn't match any known pattern	Reviewer-gated, never auto-declared — a human must confirm before this label is applied. If confirmed, a ~90-day responsible-disclosure embargo applies before public sharing

Twin rebuild: after a run completes, a fresh twin instance is prepared for the next detonation. Three things persist across every rebuild (everything else is torn down and rebuilt clean): the immutable audit store, the threat-intelligence database, and the retrained AI classifier — so the system gets incrementally smarter with every file it analyzes, even though each individual twin instance is fully disposable.

Full Timeline at a Glance

#	Stage	Component	Core checks / parameters	Output	Moves forward when
0	Entry	Network gateways (email, proxy, DNS, CASB, file-share, USB control)	File/attachment capture	File forwarded to pre-screening engine	Always, on any file crossing a gateway
1	Pre-Exploitation	Layer 1 — Fast checks	Hash lookup, YARA, ML static classifier, phishing-URL check	Raw per-check signals	Always
2	Pre-Exploitation	Layer 2 — Deep parallel checks	Static analysis, CDR, honeypot observer, ransomware time machine	Structured anomaly/behaviour signals	Always
3	Pre-Exploitation	Layer 3 — Attacker-Intent Engine	Weighted fusion of all Layer 1 + 2 signals	One 0-100 trust/risk score	Always

#	Stage	Component	Core checks / parameters	Output	Moves forward when
4	Pre-Exploitation	Layer 4 — Policy/Decision Engine	Score-to-action thresholds + org policy	Pass / Sandbox / Block decision	Medium score → Mid-Exploitation; Low → pass; High → block (stop here)
5	Mid-Exploitation	Digital-twin instantiation	Build DC, file/email/DB/backup servers, employee endpoints, detonation VM	One ephemeral twin instance, ready	Twin fully built
6	Mid-Exploitation	Covert hypervisor-level AI agent	VMI-based memory/syscall/process/network/filesystem monitoring	Continuous behaviour log	File detonated on the twin
7	Mid-Exploitation	Detonation → classification → blast-radius analysis	Full-run observation, ATT&CK mapping, malware-type classification, impact prediction	Threat classification + recommended containment (human-approved)	Run completes or times out
8	Mid-Exploitation	Disposal	VM termination, memory zeroing, disk cryptoshredding, VPC teardown	Twin instance destroyed	Always, unconditionally, after every run
9	Post-Exploitation (TRACE)	Evidence harvest + sealing	Memory dump, PCAP, filesystem diff, agent report — hash-chained + signed	Sealed evidence bundle in immutable audit store	Before disposal is allowed to proceed
10	Post-Exploitation (TRACE)	Verified disposal	Same disposal actions as Step 8, now certified	Signed disposal certificate	Disposal actions confirmed complete
11	Post-Exploitation (TRACE)	Intelligence extraction + distribution	IOC packaging, ATT&CK map, TTP-similarity, zero-day flag (reviewer-gated)	STIX/TAXII feed to MISP (instant, or ~90-day embargo if zero-day)	Classification from Step 7 is finalized
12	Post-Exploitation (TRACE)	Twin rebuild	Persist audit store, threat-intel DB, retrained classifier; rebuild clean twin	Fresh twin ready for the next detonation	Cycle repeats from Step 5 for the next medium-score file

This table is the one-page version of the whole document — every row above expands into its own full section earlier in this document with every parameter listed in detail.